

บทที่ 9

การพัฒนาระบบล็อกมอนิเตอร์

9.1 แนวคิด

ระบบล็อกมอนิเตอร์ในโครงการนี้ประกอบด้วยล็อกไฟล์จากส่วนต่าง ๆ ในระบบ ได้แก่ โดยข้อมูลส่วนใหญ่จะเป็นข้อมูลเกี่ยวกับการบุกรุก , ข้อมูลเกี่ยวกับการกระทำของผู้บุกรุกต่อระบบในส่วนต่าง ๆ , ข้อมูลเกี่ยวกับการกระทำของผู้บุกรุกในส่วนไฟร์แทรป โดยข้อมูลทั้งหมดจะถูกเก็บลงในดาต้าเบสและนำออกมาแสดงผลให้ผู้ดูแลระบบสามารถตรวจสอบการบุกรุกที่เกิดขึ้นกับระบบได้

9.2 ขอบเขตและความสามารถ

ระบบล็อกมอนิเตอร์ในโครงการนี้แบ่งออกเป็น 4 ส่วนย่อย อันได้แก่ ล็อกจากไฟร์สกรีน , ล็อกจากไฟร์ลาร์ม , ล็อกจากไฟร์เบรก และ ล็อกจากไฟร์แทรป โดยแต่ละส่วนพัฒนาด้วยเทคโนโลยีที่แตกต่างกันตามความเหมาะสม ดังนี้

9.2.1 ล็อกมอนิเตอร์ของไฟร์กรีน

โปรแกรมล็อกมอนิเตอร์ของไฟร์สกรีนนั้นแบ่งได้เป็น 2 ส่วนคือ ส่วนล็อกไฟล์ที่เกิดจากการจำแนกแพ็คเก็ตที่เข้ามาในระบบตามกฎของไฟร์วอลล์ และส่วนล็อกไฟล์ที่เกิดจากระบบตรวจจับผู้บุกรุก (Snort_inline) โดยในแต่ละส่วนจะมีขอบเขตความสามารถแตกต่างกันดังนี้

- ล็อกไฟล์จากการจำแนกแพ็คเก็ตตามกฎของไฟร์วอลล์ – เป็นโปรแกรมล็อกมอนิเตอร์ที่ถูกติดตั้งอยู่ในเครื่องแม่ข่ายที่เป็นโดเมนคอนโทรลเลอร์ (FireStation) และเก็บล็อกลงในแอ็คทีฟไดเร็คทอรี จึงพัฒนาโปรแกรมล็อกมอนิเตอร์ของไฟร์สกรีนในส่วนนี้ด้วยภาษาซีที่มีการใช้คลาส ADCONNECT ในการพัฒนาโปรแกรม

- ล็อกไฟล์จากระบบตรวจจับผู้บุกรุก – เป็นโปรแกรมล็อกมอนิเตอร์ที่เก็บล็อกของการจำแนกผู้บุกรุกออกจากผู้ใช้งานจริงโดยอาศัยโปรแกรมสนอร์ตอินไลน์ โดยจะเป็นข้อมูลเกี่ยวกับรูปแบบการบุกรุกที่ตรวจจับได้ วัน เวลา และไอพีแอดเดรสของผู้บุกรุก ซึ่งล็อกไฟล์ในส่วนนี้จะถูกเก็บลงฐานข้อมูลที่อยู่ในเครื่องดาต้าเบสเซิร์ฟเวอร์ของระบบ ซึ่งข้อมูลต่าง ๆ ในเครื่อง LogServer จะถูกส่งออกมาแสดงทางโปรแกรม Tartarus Management

9.2.2 โปรแกรมล็อกมอนิเตอร์ของไฟร้อลาร์ม

ใช้การเขียนโปรแกรมผ่านทางซ็อกเก็ตเพื่อรับข้อมูลจากไฟร้อลาร์มและจัดเก็บลงดาต้าเบส จึงพัฒนาโปรแกรมล็อกมอนิเตอร์ด้วยภาษา C ที่มีคลาส CAsyncSocket ในการติดต่อ

9.2.3 โปรแกรมล็อกมอนิเตอร์ของไฟร์แทรป

เป็นล็อกไฟล์เกี่ยวกับการกระทำของผู้บุกรุกที่กระทำต่อเครื่องกับดักในระบบไฟร์แทรป โดยในการบันทึกพฤติกรรมของผู้บุกรุกจะใช้โปรแกรมเซเบคโคลเอนด์ที่อยู่ในเครื่องกับดักเป็นตัวดักจับพฤติกรรมต่าง ๆ แล้วส่งข้อมูลต่าง ๆ ไปให้โปรแกรมเซเบคเซิร์ฟเวอร์ที่อยู่ในเครื่องดาต้าเบส เซิร์ฟเวอร์ของระบบ แล้วนำออกมาแสดงผลให้ผู้ดูแลระบบตรวจสอบผ่านทางโปรแกรม Tartarus Management โดยข้อมูลต่าง ๆ ที่ได้จากไฟร์แทรป เช่น

- ข้อมูลเบื้องต้นของผู้บุกรุก เช่น หมายเลขไอพีแอดเดรส
- ข้อมูลการป้อนคำสั่ง หรือ keystroke ของผู้บุกรุก
- ข้อมูลที่นำเข้าหรือออก อาจเป็นไฟล์หรือเครื่องมือที่ผู้บุกรุกจะนำมาใช้
- ข้อมูลที่ส่งออกจากเครื่องกับดัก อาจเป็นข้อมูลหรือเป็นการกระทำเพื่อโจมตีระบบ

9.2.4 โปรแกรมล็อกมอนิเตอร์ของไฟร์เบรก

เป็นล็อกไฟล์เกี่ยวกับการบุกรุกของผู้บุกรุกที่เข้ามาในระบบไฟร์เบรก โดยหลังจากที่โปรแกรมสนอร์ตอินไลน์ในไฟร์เบรกตรวจพบรูปแบบการบุกรุกที่เกิดขึ้นและทำการตัดการเชื่อมต่อ นั้น ๆ โปรแกรมสนอร์ตอินไลน์ในไฟร์เบรกจะทำการส่งล็อกไฟล์เหตุการณ์ที่เกิดขึ้นไปแสดงผลที่โปรแกรม Tatarus Management

9.3 เทคโนโลยีที่ใช้และการพัฒนาโปรแกรม

9.3.1 ล็อกมอนิเตอร์ของไฟร์สกรีน

- ล็อกไฟล์จากการจำแนกแพ็คเก็ตตามกฎของไฟร์วอลล์

ล็อกไฟล์ในส่วนนี้จะทำการพัฒนาโดยภาษา C โดยการใช้คลาส ADCONNECT ที่ใช้ในการติดต่อกับแอ็คทีฟไดเรกทอรี เพื่อเข้าถึงค่าของล็อกไฟล์ที่ถูกส่งมาเก็บยังแอ็คทีฟไดเรกทอรี จากนั้นจะนำค่าที่ได้นี้มาลงไฟล์ดาต้าเบสที่สร้างจาก Microsoft Access ที่มีชื่อว่า LogfireScreen โดยมีโครงสร้างตารางที่ใช้ในการเก็บล็อกของเครื่องลูกข่ายดังตารางที่ 9.1 และแสดงผลผ่านโปรแกรม

ชื่อเขตข้อมูล	ชนิดข้อมูล	คำอธิบาย
LogNo (คีย์หลัก)	NUMBER	หมายเลขลำดับที่ของล็อก
Date	TEXT	วันที่
Time	TEXT	เวลา
In	TEXT	อินเตอร์เฟซขาเข้า
Out	TEXT	อินเตอร์เฟซขาออก
Mac	TEXT	หมายเลขแม็คแอดเดรส
Source	TEXT	หมายเลขไอพีต้นทาง
Destination	TEXT	หมายเลขไอพีปลายทาง
Protocol	TEXT	โปรโตคอล
Source Port	TEXT	หมายเลขพอร์ตต้นทาง
Destination Port	TEXT	หมายเลขพอร์ตปลายทาง
Type	TEXT	รูปแบบของไอซีเอ็มพี

ตารางที่ 9.1 แสดงโครงสร้างตารางที่ใช้ในการเก็บล็อกของเครื่องเกตเวย์

- ล็อกไฟล์จากระบบตรวจจับผู้บุกรุก

ล็อกไฟล์ในส่วนนี้เป็นล็อกที่ได้จากโปรแกรมตรวจจับสนอร์ตอินไลน์ที่อยู่ในไฟร์สกรีน โดยข้อมูลจะถูกส่งมาเก็บไว้ในเครื่องเซิร์ฟเวอร์ฐานข้อมูล (LogServer) ซึ่งใช้ในการจัดเก็บข้อมูลลงฐานข้อมูล MySQL เพื่อความเป็นระบบ และสามารถเข้าใช้งานได้อย่างเป็นระบบ เพื่อเชื่อมต่อข้อมูลให้โปรแกรมควบคุม Tartarus Management สามารถมาดึงไปใช้งานได้ และรองรับการเชื่อมต่อข้อมูลในการพัฒนาในอนาคต

9.3.2 ล็อกมอไนเตอร์ของไฟร์วอลล์

โปรแกรมนี้จะทำการพัฒนาโดยภาษา C โดยการใช้คลาส CAsyncSocket ที่ใช้ในการสร้าง Socket และทำเป็นเครื่องแม่ข่าย (Server) รองรับการติดต่อมาจากเครื่องลูกข่าย (Client) เมื่อเกิดเหตุการณ์โจมตีขึ้น จากนั้นจะนำค่าที่ได้นี้มาลงไฟล์ดาต้าเบสที่สร้างจาก Microsoft Access ที่มีชื่อว่า LogfireAlarm โดยมีโครงสร้างตารางที่ใช้ในการเก็บล็อกของเครื่องลูกข่ายดังตารางที่ 9.2 และแสดงผลผ่านทางโปรแกรม

ชื่อเขตข้อมูล	ชนิดข้อมูล	คำอธิบาย
LogNo (คีย์หลัก)	NUMBER	หมายเลขลำดับที่ของล็อก
AttackDst	TEXT	หมายเลขไอพีปลายทาง
AttackSrc	TEXT	หมายเลขไอพีต้นทาง
AttackType	TEXT	ชนิดของการโจมตี
AttackDate	TEXT	วันที่
AttackTime	TEXT	เวลา
User	TEXT	ชื่อผู้ใช้
Group	TEXT	กลุ่มผู้ใช้

ตารางที่ 9.2 แสดงโครงสร้างตารางที่ใช้ในการเก็บล็อกของเครื่องลูกข่าย

9.3.3 ล็อกมอเนเตอร์ของไฟร์แตรป

เป็นล็อกไฟล์ที่แสดงข้อมูลเกี่ยวกับการกระทำของผู้บุกรุกที่กระทำเมื่ออยู่ในเครื่องกับดักไฟร์แตรป เช่น Keystroke ของผู้บุกรุก ไอพีแอดเดรสของผู้บุกรุก การนำไฟล์เข้าออกจากระบบของผู้บุกรุก รวมถึงการเปลี่ยนแปลงของไฟล์ภายในเครื่องกับดัก ซึ่งข้อมูลต่าง ๆ จะถูกส่งมาจากโปรแกรมเซเบคไคลเอนด์ และโปรแกรมเซมเฮนที่ทำงานอยู่ในเครื่องกับดัก มาเก็บไว้ในเครื่องเซิร์ฟเวอร์ฐานข้อมูล (LogServer) โดยในเครื่องฐานข้อมูลนี้จะมีโปรแกรมเซเบคเซิร์ฟเวอร์และเซมเฮน (Yule) เป็นตัวรับข้อมูลมาเก็บในฐานข้อมูล Mysql อีกทีหนึ่ง

Sebek_server

เซเบคเซิร์ฟเวอร์ เป็นส่วนที่ทำหน้าที่รับค่าข้อมูลที่เซเบคไคลเอนด์ดักจับได้จากเครื่องกับดัก และระบบการทำงานจะส่งค่ามาเก็บยังฐานข้อมูลที่จัดเตรียมไว้ ซึ่งจะส่งผ่านไปด้วยโปรโตคอลยูดีพี พร้อมทั้งเข้ารหัสลับไว้ โดยไม่จำเป็นจะต้องระบุไอพีปลายทางเพื่อความปลอดภัย จะระบุเป็น MAC Address ของเครื่องเซิร์ฟเวอร์ ซึ่งเครื่องไคลเอนด์ไม่จำเป็นต้องมีการ ARP Request เพื่อหาปลายทางซึ่งจะช่วยลดความผิดสังเกตจากผู้บุกรุกได้ และการทำงานของเซเบคไคลเอนด์ จะทำการ by-pass ผ่าน TCP stack คือมันจะสร้างแพ็คเก็ตเองเลย ทำให้โปรแกรมจำพวก sniffer ที่ผู้บุกรุกอาจนำเข้ามาติดตั้งในเครื่องกับดัก ไม่สามารถตรวจพบ

Samhain (Yule)

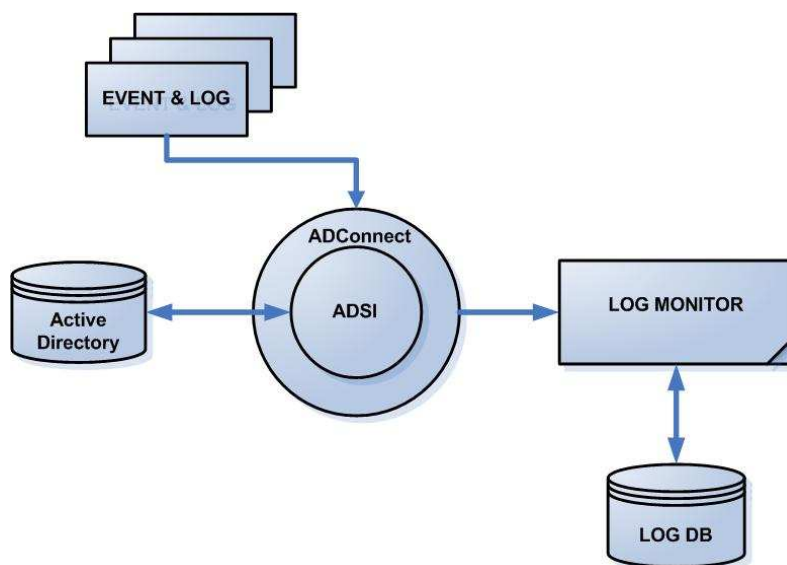
เซมเฮนในส่วนนี้จะเป็นเซอร์วิสที่ทำหน้าที่ในการรับข้อมูลจากเซมเฮนที่อยู่บนเครื่องกับดักมาบันทึกเก็บไว้ในฐานข้อมูลที่จัดเตรียมไว้

9.3.4 ล็อกมอนิเตอร์ของไฟร์เบรก

เป็นล็อกไฟล์เกี่ยวกับการบุกรุกของผู้บุกรุกที่เข้ามาในระบบไฟร์เบรก โดยหลังจากที่โปรแกรมสนอร์ตอินไลน์ในไฟร์เบรกตรวจพบรูปแบบการบุกรุกที่เกิดขึ้นและทำการปิดการเชื่อมต่อ นั้น ๆ โปรแกรมสนอร์ตอินไลน์ ในไฟร์เบรกจะบันทึกล็อกไฟล์ลงใน `/var/log/snort_inline/snort_inline-fast` และ `/var/log/snort_inline/snort_inline-full` จากนั้นไฟร์เบรกการส่งล็อกไฟล์ไปแสดงผลที่โปรแกรม Tatarus Management

9.4 การทำงานของโปรแกรม

ในการทำงานของระบบล็อกมอนิเตอร์ที่ทำงานร่วมกับความสามารถของบริการแอ็คทีฟไดเรกทอรี (Active directory) ของ Windows server 2003 จะมีการทำงานโดยที่ข้อมูลจะเก็บอยู่ในฐานข้อมูลของแอ็คทีฟไดเรกทอรี (Active Directory Database) และเข้าถึงข้อมูลผ่าน ADSI ไปยังที่ไฟไดเรกทอรีเซอร์วิส (Active Directory Services) เพื่อเข้าถึงข้อมูลที่จัดเก็บ ซึ่งการทำงานของล็อกมอนิเตอร์ที่ทำงานร่วมกันกับแอ็คทีฟไดเรกทอรี (Active Directory) แสดงโครงสร้างการทำงาน ดังรูปที่ 8.1



รูปที่ 9.1 แสดงโครงสร้างการทำงานระหว่างล็อกมอนิเตอร์กับแอ็คทีฟไดเรกทอรี

ส่วนโปรแกรมล็อกมอนิเตอร์ของไฟร์เบรกนั้นจะการทำงานโดยการติดต่อกับดาต้าเบส MySQL โดยตรงด้วยการส่งคำสั่ง SQL ผ่านทางโปรแกรมเพื่อทำการ Select ROW ที่ต้องการมาแสดงผลคือ Row ที่อยู่ในตาราง Event, Signature, Sensor โดยคำสั่ง SQL ที่ส่งเข้าไบนั้นจะเป็นการ Select ดังต่อไปนี้

1. ค่า NO. คือค่าของ Cid ในตาราง Event
2. ค่า Source IP คือค่าของ Hostname ในตาราง Sensor
3. ค่า Acctack Type คือค่าของ Sig_name ในตาราง Signature
4. ค่า Acctack Time คือค่าของ TimeStamp ในตาราง Event